



LAHORE GARRISON UNIVERSITY

SOFTWARE VERIFICATION & VALIDATION

QUIZ NO 5&6

SUBMITTED TO: MAM. JAWARIA RMZAN

SUBMITTED BY:

FAIZAN MUHYUDDIN

FA-2023/BSSE/072 (C)

LAHORE GARRISON UNIVERSITY

1. VALIDATION CHECKLIST ENGINEERING

1.1 Measurable Validation Criteria

The following measurable criteria are derived from stakeholder requirements:

Requirement	Validation Criteria	Measurement Method	Expected Outcome
Secure Login	Authentication must be encrypted and verified	Login testing with valid/invalid inputs	Only authorized users gain access
Transaction Accuracy	Financial records must be consistent	Database verification	No mismatch in transactions
Session Timeout	User session must expire after inactivity	Inactivity testing	Automatic logout occurs
Mobile Responsiveness	System should adapt to different screen sizes	Device and browser testing	Proper UI layout on all devices
Audit Logging	All system activities must be recorded	Log file inspection	Complete and accurate audit trail

1.2 Validation Checklist

A structured checklist is prepared to ensure systematic validation of system features:

ID	Feature	Validation Point	Method	Status	Evidence
1	Login System	Secure authentication	Manual testing	Pass	Screenshots
2	Transaction System	Data accuracy	Database verification	Pass	Log records
3	Session Control	Auto logout feature	Idle testing	Pass	System logs
4	User Interface	Mobile compatibility	Device testing	Pass	UI screenshots

ID	Feature	Validation Point	Method	Status	Evidence
5	Audit System	Activity tracking	Log review	Pass	Audit reports

2. CI VALIDATION WORKFLOW (GITHUB ACTIONS)

2.1 Explanation

Continuous Integration (CI) validation is used to automatically test and verify software whenever changes are made. It ensures that every update is checked for errors, functionality issues, and quality compliance.

This automated approach improves reliability, reduces manual testing effort, and provides continuous validation evidence for every code change.

2.2 CI Validation Process

The CI pipeline performs the following steps:

- Code is automatically retrieved from the repository after each update
- System dependencies are installed
- Automated tests are executed to verify functionality
- A validation report is generated to summarize results
- The report is stored as evidence for future audit and review

3. SECURITY-ORIENTED VALIDATION (OWASP ZAP)

3.1 Role of Security Validation

Security-oriented validation ensures that the software is protected against vulnerabilities before deployment. It verifies that the system is resistant to attacks and meets security compliance standards.

It helps identify weaknesses in authentication, data handling, and input processing.

3.2 Common Structural Vulnerabilities

1. SQL Injection

This occurs when attackers manipulate input fields to execute unauthorized database queries. It can lead to data theft or modification.

2. Cross-Site Scripting (XSS)

This vulnerability allows attackers to inject malicious scripts into web pages, which can steal user session data or perform unauthorized actions.

3. Broken Authentication

Weak authentication mechanisms can allow attackers to bypass login systems and access sensitive user accounts.

3.3 OWASP ZAP Security Validation Workflow

The security validation process using OWASP ZAP includes the following steps:

- The target application is selected for testing
- Passive scanning is performed to analyze application traffic without attacking the system
- Active scanning is conducted to simulate real attack scenarios
- Vulnerabilities are identified and analyzed based on scan results
- Each issue is classified based on severity level such as high, medium, or low
- Findings are documented as evidence for reporting and compliance

3.4 Vulnerability Findings

Vulnerability	Severity	Location	Evidence	Suggested Fix
SQL Injection	High	Login Module	Scan report	Use secure parameterized queries

Vulnerability	Severity	Location	Evidence	Suggested Fix
Cross-Site Scripting	Medium	Input fields	Security alert logs	Sanitize user input
Missing Security Headers	Low	Server configuration	Scan output	Add security headers

4.VALIDATION RISK AND COMPLIANCE

4.1 Validation Risk Register

The following risks are identified in the system:

Risk ID	Risk Description	Impact	Likelihood	Severity	Mitigation
R1	Unauthorized data access	High	High	Critical	Strong authentication mechanisms
R2	Data leakage	High	Medium	High	Encryption and secure storage
R3	Session hijacking	Medium	Medium	Medium	Secure session management

4.2 Compliance Evidence Compilation

Compliance documentation is maintained to ensure audit readiness and traceability. The evidence includes validation checklists, security scan reports, risk assessments, and testing results.

This structured documentation ensures that all validation activities are properly recorded and can be reviewed during audits or quality assessments.

